UNIVERSITY OF KELANIYA / SENG 34213

FOREVER HOTEL MANAGEMENT SYSTEM

OWASP Compliance Evidence

OWASP Top 10 (2021) Control Review | Six Subsystems

Reporting date: 25 October 2026. Evidence is identified by subsystem branch, commit, and run date; comparisons across different revisions are not a single hotel-wide release test.

Contents

1. Security evidence overview

2. Hotel Website (HW)

3. Manager Dashboard (MAD)

4. Front Desk System (FDS)

5. Food Ordering and Service Requests (FOSS)

6. Kitchen Management System (KMS)

7. Worker Management System (WKMS)

8. Outstanding security acceptance

---

1. Security evidence overview

Security evidence is reviewed against OWASP A01-A10. Passing automated tests show the behavior asserted by those tests. They do not alone constitute a completed penetration test, a fully deployed TLS security assessment, or an independently approved compliance certification.

Dependency-audit results and their scope

Hotel Website

Backend npm install: 20 moderate findings; frontend npm install: 6 high findings. A blocking high-severity dependency audit stage was not verified in the matching workflows.

Manager Dashboard

Current backend npm audit failed: 3 high and 1 moderate advisories (body-parser, multer/platform-express and fast-uri reported); frontend audit gate passed under its configured exception policy.

Front Desk System

Backend high-threshold audit and frontend production-only audit reported zero in their respective scopes; separate full frontend audit reported one high-severity undici development dependency finding.

Food Ordering and Service Requests

Historical backend high-threshold audit passed despite 21 moderate advisories; frontend production-only audit passed, while installation reported 5 high full-tree findings. Feature security job was branch-skipped.

Kitchen Management System

Backend/frontend production-only high-threshold audits passed with zero findings in that filtered scope; full npm installs reported backend 20 moderate + 1 critical and frontend 19 moderate + 5 high advisories.

Worker Management System

Backend/frontend production-only audits passed with zero findings; initial full frontend installation reported one high-severity finding in the wider dependency set.

A production-only or severity-threshold audit pass is not equivalent to a clean all-dependency audit. Advisory counts reflect the cited CI snapshots and may change at a later release.

Control coverage

All 60 subsystem/category combinations (six subsystems multiplied by ten OWASP categories) are set out below. Each category preserves the evidence and unresolved verification points recorded for that service.

2. Hotel Website (HW)

Repository: forever-hotel/hotel-website | Branch: pre-develop | Tested revision: 606acf0674a18621639bce572ce3577af933cd63 | CI date: 22 October 2026

Evidence: https://github.com/forever-hotel/hotel-website/actions/runs/39726186380, https://github.com/forever-hotel/hotel-website/actions/runs/39726186472, https://github.com/forever-hotel/hotel-website/actions/runs/39726186469

Dependency position: Backend npm install: 20 moderate findings; frontend npm install: 6 high findings. A blocking high-severity dependency audit stage was not verified in the matching workflows.

A01 Broken Access Control

Broken Access Control PARTIALLY EVIDENCED JWT guest guard and restrictive role-field DTO tests exist; booking ownership / object-level access not end-to-end tested. backend/src/common/guards/jwt-auth.guard.spec.ts; backend/test/integration/guest-registration.integration-spec.ts

Required follow-up Add IDOR tests across all future booking/profile endpoints.

A02 Cryptographic Failures

Cryptographic Failures PARTIALLY EVIDENCED bcrypt hashing is tested; JWT HS256 signature, invalid/expired tokens tested. Production TLS, cookie policy and secret rotation require deployment proof. backend/src/guests/password-hasher.service.spec.ts; backend/src/common/utils/jwt-token.service.spec.ts

Required follow-up Verify staging HTTPS, secure cookies, key rotation and data encryption.

A03 Injection

Injection PARTIALLY EVIDENCED class validation and parameterized repository queries are used; malformed/extra fields rejected. Exhaustive injection testing not demonstrated. backend/test/integration/guest-registration.integration-spec.ts; backend/src/database/repositories/guest.repository.ts

Required follow-up Run malicious SQL/HTML input tests for contact, search and auth paths.

A04 Insecure Design

Insecure Design NOT FULLY VERIFIED Backend guest auth, stay validation and inventory query tests exist; formal threat-model review and last-room reservation race proof absent from pre-develop. backend/test/integration/availability.integration-spec.ts; backend/test/integration/booking-payment.integration-spec.ts

Required follow-up Review threat model and test inventory conflicts when reservation commands are implemented.

A05 Security Misconfiguration

Security Misconfiguration PARTIALLY EVIDENCED Joi environment validation, global error formatting and fail-closed availability errors present; cloud deployment configuration unverified. backend/src/config/env.validation.spec.ts; backend/src/common/filters/all-exceptions.filter.spec.ts

Required follow-up Run staging config review, restrict CORS, and check production error disclosure.

A06 Vulnerable and Outdated Components

Vulnerable and Outdated Components OPEN FINDINGS Latest matching install reported 20 moderate backend vulnerabilities and 6 high frontend vulnerabilities; CI has no blocking audit step. Package-level audit proof absent. HW Backend CI 39726186380; Frontend CI 39726186472

Required follow-up Perform npm audit --json in safe copy, triage/upgrades, record package/CVE and add CI security gate.

A07 Identification and Authentication Failures

Identification and Authentication Failures PARTIALLY EVIDENCED JWT expiry/signature denial and credential rejection tests exist. Account lockout, MFA (if required), gateway brute-force controls not established. backend/src/common/utils/jwt-token.service.spec.ts; backend/test/integration/guest-auth.integration-spec.ts

Required follow-up Verify login throttling and production authentication abuse tests.

A08 Software and Data Integrity Failures

Software and Data Integrity Failures PARTIALLY EVIDENCED npm ci and pinned lockfiles used; backend schema synchronization disabled. Signing/provenance and dependency update controls not verified. backend/package-lock.json; frontend/package-lock.json; .github/workflows/backend-ci.yml

Required follow-up Add SCA gate, signed provenance policy and migration review evidence.

A09 Security Logging and Monitoring Failures

Security Logging and Monitoring Failures PARTIALLY EVIDENCED Application logger/error formatter tests exist; centralized monitoring and redacted auth-failure logging in deployed stack not demonstrated. backend/src/common/utils/app-logger.spec.ts; backend/src/common/filters/all-exceptions.filter.spec.ts

Required follow-up Test production security log coverage and alerting without guest PII.

A10 Server-Side Request Forgery

Server-Side Request Forgery NOT VERIFIED Contact email integration is a constrained outbound path, but static remote target allowlist and SSRF pen-tests not evidenced. backend/src/contact/contact.service.ts

Required follow-up Test blocking of attacker-controlled external URLs and constrain egress.

3. Manager Dashboard (MAD)

Repository: forever-hotel/manager-dashboard | Branch: development | Tested revision: bba65a0762286d4b0ac902865d7a2dd1e683e9c7 | CI date: 24 October 2026

Evidence: https://github.com/forever-hotel/manager-dashboard/actions/runs/40137091073, https://github.com/forever-hotel/manager-dashboard/actions/runs/39847903811

Dependency position: Current backend npm audit failed: 3 high and 1 moderate advisories (body-parser, multer/platform-express and fast-uri reported); frontend audit gate passed under its configured exception policy.

A01 Broken Access Control

Broken Access Control | PARTIALLY VERIFIED JWT/role checks, protected navigation and read-only task interfaces are source-tested; isolated route/role checks do not substitute for penetration testing.

Evidence: backend/src/common/security-boundaries.spec.ts; frontend/test/protection.test.ts

A02 Cryptographic Failures

Cryptographic Failures | PARTIALLY VERIFIED JWT signing/verification, bcrypt password hashing and encrypted staff credential deliveries are unit-tested; full secret/key management and TLS deployment are not independently verified.

Evidence: backend/src/auth/token.service.spec.ts; backend/src/staff/staff.spec.ts

A03 Injection

Injection | PARTIALLY VERIFIED DTO validation, parameterised database filters and CSV formula injection protection appear in tests; no standalone full fuzzing/DAST evidence retrieved.

Evidence: backend/src/promotions/promotions.spec.ts; backend/src/reports/reports.spec.ts

A04 Insecure Design

Insecure Design | PARTIALLY VERIFIED Optimistic-version conflict, account lockout, atomic promotion/complaint workflows, and fail-closed states have tests; holistic threat-model sign-off unavailable.

Evidence: backend/test/promotions.e2e-spec.ts; backend/test/complaints.e2e-spec.ts

A05 Security Misconfiguration

Security Misconfiguration | PARTIALLY VERIFIED Security response headers, default restrictions and configuration checks have tests; production infrastructure and headers not independently observed.

Evidence: frontend/test/security-headers.test.ts; backend/src/config/environment.spec.ts

A06 Vulnerable and Outdated Components

Vulnerable and Outdated Components | FAILED - OPEN FINDINGS Latest backend npm audit --audit-level=high failed; output records 3 high and 1 moderate vulnerabilities. Previous fully successful run had 20 moderate vulnerabilities, no high.

Evidence: CI run #40137091073, backend job #121000794805

A07 Identification and Authentication Failures

Identification and Authentication Failures | PARTIALLY VERIFIED Active-account checks, login lockout, JWT validity, first-password change and session routing tests exist. Live identity-provider acceptance not independently tested.

Evidence: backend/src/auth/auth.service.spec.ts; frontend/test/protection.test.ts

A08 Software and Data Integrity Failures

Software and Data Integrity Failures | PARTIALLY VERIFIED CI locked installs, validation, changed coverage gates, confirmation/retry outbox tests present. Complete supply-chain attestation, protected release verification not established.

Evidence: .github/workflows/ci.yml; backend/src/promotions/promotion-publication.spec.ts

A09 Security Logging and Monitoring Failures

Security Logging and Monitoring Failures | PARTIALLY VERIFIED Staff audit recording, redaction, safe errors and notifications are source-tested. Central log retention, alerting SLAs and 12-month retention unverified.

Evidence: backend/src/staff/staff-reset.spec.ts; backend/src/staff/staff-profiles.spec.ts

A10 Server-Side Request Forgery

Server-Side Request Forgery | NOT INDEPENDENTLY VERIFIED No targeted SSRF/egress allowlist penetration-test results were retrieved; do not mark compliant from generic input validation.

Evidence: No verified targeted SSRF run

4. Front Desk System (FDS)

Repository: forever-hotel/front-desk | Branch: develop | Tested revision: 503465b7eb2c29b56cc2ec0d329d91d6b40853d4 | CI date: 24 October 2026

Evidence: https://github.com/forever-hotel/front-desk/actions/runs/40057114169, https://github.com/forever-hotel/front-desk/actions/runs/40057114175

Dependency position: Backend high-threshold audit and frontend production-only audit reported zero in their respective scopes; separate full frontend audit reported one high-severity undici development dependency finding.

A01 Broken Access Control

Broken Access Control PARTIALLY EVIDENCED JWT, RBAC read/write roles and 401/403 E2E tests available. Not an audited guarantee for every endpoint.

Source backend/test/bookings-rbac.e2e-spec.ts; backend/test/check-in-rbac.e2e-spec.ts; backend/test/rooms-rbac.e2e-spec.ts

Follow-up Produce endpoint/role access matrix; negative tests for every protected endpoint.

A02 Cryptographic Failures

Cryptographic Failures NOT FULLY VERIFIED JWT signature and issuer tests exist; password hashing with bcrypt cost >=12 and production TLS/hashed refresh tokens are central-auth/deployment responsibilities, not established by FDS CI.

Source backend/src/security/auth/jwt-principal.resolver.spec.ts; backend/src/config/env.validation.spec.ts

Follow-up Obtain central auth evidence for bcrypt >=12, token handling and actual staging HTTPS/TLS.

A03 Injection

Injection PARTIALLY EVIDENCED PostgreSQL repository uses parameter placeholders; DTO and text sanitation tests present. Exhaustive injection fuzzing not shown.

Source backend/src/reservations/repositories/postgres-booking.repository.ts; backend/src/security/sanitization/sanitize-plain-text.spec.ts

Follow-up Perform targeted SQL/NoSQL injection and input validation tests per route.

A04 Insecure Design

Insecure Design NOT VERIFIED Transaction/audit protections have code and tests; signed threat model/design security review not verified from CI.

Source backend/test/database/postgres-checkout.repository.integration-spec.ts; backend/test/database/audit-append-only.integration-spec.ts

Follow-up Link reviewed SDS threat model and architecture/security review decisions.

A05 Security Misconfiguration

Security Misconfiguration PARTIALLY EVIDENCED Staging/production env validation checks JWT secrets, wildcard origins and DB_SYNCHRONIZE; deployed error handling / default credentials not verified.

Source backend/src/config/env.validation.spec.ts; backend/src/config/env.validation.ts

Follow-up Run hardened staging configuration test and production error disclosure review.

A06 Vulnerable and Outdated Components

Vulnerable Components OPEN FINDING Backend high-level dependency audit passed (0 findings). Frontend production-only audit passed (0). Nonblocking full frontend audit found 1 HIGH in dev-dependency undici 8.0.0-8.12.1.

Source Backend CI 40057114169; Frontend CI 40057114175

Follow-up Remediate/update undici as feasible, rerun full audit, document accepted residual risk before sign-off.

A07 Identification and Authentication Failures

Authentication Failures PARTIALLY EVIDENCED JWT invalid/expired/issuer/signature denial tested; centralized login rate limiting/account lockout not evidenced in FDS.

Source backend/src/security/auth/jwt-principal.resolver.spec.ts; backend/test/realtime.e2e-spec.ts

Follow-up Obtain central authentication service lockout/session rotation tests.

A08 Software and Data Integrity Failures

Software and Data Integrity Failures PARTIALLY EVIDENCED package-lock.json present; npm ci used in CI; append-only audit DB trigger tested. Full artifact signing / supply chain provenance not verified.

Source backend/package-lock.json; frontend/package-lock.json; .github/workflows/backend-ci.yml

Follow-up Review dependency provenance/build integrity and migration/change control.

A09 Security Logging and Monitoring Failures

Security Logging and Monitoring Failures PARTIALLY EVIDENCED Audit logging and PII/secret redaction tests exist; comprehensive auth-failure/data access logging and monitoring not proven.

Source backend/src/security/redaction/log-redactor.spec.ts; backend/test/database/audit-append-only.integration-spec.ts

Follow-up Verify staged auth/authorization failure logging with redacted records and alerting.

A10 Server-Side Request Forgery

Server-Side Request Forgery NOT VERIFIED WKMS HTTP integration client exists; no dedicated SSRF/URL allow-list test was located in reviewed evidence.

Source backend/src/integrations/wkms/wkms-http.client.spec.ts

Follow-up Verify fixed trusted service endpoint and outbound allowlist; test rejected untrusted URLs.

5. Food Ordering and Service Requests (FOSS)

Repository: forever-hotel/food-ordering | Branch: develop / feature/34-booking-room-verification | Tested revision: 17af08411e / 343b7d0018 | CI date: 13 October 2026

Evidence: https://github.com/forever-hotel/food-ordering/actions/runs/38381405941, https://github.com/forever-hotel/food-ordering/actions/runs/38419260802

Dependency position: Historical backend high-threshold audit passed despite 21 moderate advisories; frontend production-only audit passed, while installation reported 5 high full-tree findings. Feature security job was branch-skipped.

A01 Broken Access Control

Broken Access Control - PARTIAL / NOT VERIFIED

Observed: Checked-in status and room match are validated by a mock booking-provider unit suite. No live FDS authority, production session claims or request authorization proof.

Required verification: Exercise live booking-owner/room-role rules, deny missing/revoked tokens and replayed sessions.

A02 Cryptographic Failures

Cryptographic Failures - NOT VERIFIED

Observed: foss_sessions maps a VARCHAR session_token with uniqueness; this alone does not establish secure token generation, hashing, storage or rotation.

Required verification: Review token entropy, transport, secret storage and expiration/revocation and database disclosure impact.

A03 Injection

Injection - PARTIAL / NOT VERIFIED

Observed: TypeORM repository methods accept structured filter objects; SQL injection and malicious guest payload tests were not identified.

Required verification: Run API validation, SQL and output-encoding tests for all future guest-input endpoints.

A04 Insecure Design

Insecure Design - PARTIAL

Observed: Booking verification rejects non-checked-in statuses and invalid stay windows using a development-only provider.

Required verification: Replace mock authorization provider with approved owner service; verify fail-closed behavior in integrated staging.

A05 Security Misconfiguration

Security Misconfiguration - PARTIAL

Observed: PostgreSQL 16 ephemeral CI service; migrations and lint/build executed. Configuration review and production hardening are not independently tested.

Required verification: Verify secure headers, CORS, HTTPS, debug flags, cookies and isolated database credentials.

A06 Vulnerable and Outdated Components

Vulnerable and Outdated Components - PARTIAL

Observed: Historical develop security job passed the configured backend audit at high threshold and frontend production-only audit. Full backend audit still listed 21 moderate findings; frontend installation listed 5 high advisories across all deps.

Required verification: Rerun separate all-dependency and production-only JSON audits against final lockfiles, triage and remediate.

A07 Identification and Authentication Failures

Identification and Authentication Failures - PARTIAL / NOT VERIFIED

Observed: Mock provider validates booking state/room/date, but there is no verified frontend login or token lifecycle E2E result.

Required verification: Verify guest JWT ownership, expiry, logout and FDS-driven invalidation with actual services.

A08 Software and Data Integrity Failures

Software and Data Integrity Failures - PARTIAL

Observed: Migration tests verify session uniqueness, required fields, rollback/reapply; CI builds and tests on immutable SHAs.

Required verification: Add broker/event payload validation and idempotency checks for live cross-service requests.

A09 Security Logging and Monitoring Failures

Security Logging and Monitoring Failures - NOT VERIFIED

Observed: No audited guest action/error logging, correlation or alerting evidence in evaluated source/tests.

Required verification: Add structured redacted audit logs and monitor abnormal activity and token abuse.

A10 Server-Side Request Forgery

Server-Side Request Forgery - NOT VERIFIED

Observed: No independently tested SSRF controls for outbound inter-service requests; mock provider performs no real HTTP.

Required verification: Restrict and verify upstream destinations and prevent arbitrary URL forwarding.

6. Kitchen Management System (KMS)

Repository: forever-hotel/kitchen-management | Branch: develop | Tested revision: 89087002ac2df8f07b6140c00111979c75bc2799 | CI date: 10 October 2026

Evidence: https://github.com/forever-hotel/kitchen-management/actions/runs/38038213541

Dependency position: Backend/frontend production-only high-threshold audits passed with zero findings in that filtered scope; full npm installs reported backend 20 moderate + 1 critical and frontend 19 moderate + 5 high advisories.

A01 Broken Access Control

Broken Access Control - Unverified

Source-supported observation: Only scaffold/health HTTP tests are present. No evidence of kitchen manager/staff RBAC tests for operational APIs on develop.

Remaining verification: Implement and test role-sensitive, object-scoped endpoint authorization.

A02 Cryptographic Failures

Cryptographic Failures - Partial

Source-supported observation: Database config tests check managed PostgreSQL SSL and certificate verification; no complete token/session or secrets management review.

Remaining verification: Verify secrets, cryptography, transport and credential storage in deployment.

A03 Injection

Injection - Partial

Source-supported observation: Joi environment validation is tested; repository lookup tests exercise repository methods, but not an end-to-end hostile-input test suite.

Remaining verification: Test hostile input, SQL injection and untrusted text at operational API boundaries.

A04 Insecure Design

Insecure Design - Partial

Source-supported observation: Domain entity tests assert referential mappings, positive quantity/price checks and historical order snapshots.

Remaining verification: Add negative business-rule, authorization, transition and concurrency tests.

A05 Security Misconfiguration

Security Misconfiguration - Partial

Source-supported observation: Environment validation and startup checks exist; local DB synchronization disabled, managed DB SSL tests.

Remaining verification: Harden production CORS, origins, error handling, database rights and secret rotation.

A06 Vulnerable and Outdated Components

Vulnerable/Outdated Components - Partial

Source-supported observation: Both CI npm audit --omit=dev --audit-level=high steps passed with zero production-scoped vulnerabilities. Installation output reported other dependencies: backend 20 moderate + 1 critical, frontend 19 moderate + 5 high.

Remaining verification: Investigate full dependency tree; capture current comprehensive npm audit and remediate findings.

A07 Identification and Authentication Failures

Identification/Authentication Failures - Not Verified

Source-supported observation: Only root/health endpoints are demonstrated in evaluated develop; no full kitchen authentication and role tests.

Remaining verification: Implement/test staff login, token validation, expiry, session revocation, account lockout.

A08 Software and Data Integrity Failures

Software/Data Integrity Failures - Partial

Source-supported observation: npm ci uses lockfiles; lint/tests/build run in GitHub Actions. No production artifact provenance or event envelope verification documented.

Remaining verification: Verify signed release processes, message validation, integrity checks and rollout.

A09 Security Logging and Monitoring Failures

Security Logging/Monitoring Failures - Not Verified

Source-supported observation: No dedicated security log, alert, audit-retention or redaction test suite in evaluated develop.

Remaining verification: Add audit event tests, secret redaction and monitoring evidence.

A10 Server-Side Request Forgery

Server-Side Request Forgery - Not Verified

Source-supported observation: No SSRF-specific review or tests for operational external requests.

Remaining verification: Restrict outbound destinations and prove URL validation where outbound calls exist.

7. Worker Management System (WKMS)

Repository: forever-hotel/worker-management | Branch: develop | Tested revision: 0f91f1c9d6390c80c9f12f82b834fee9bf374104 | CI date: 25 October 2026

Evidence: https://github.com/forever-hotel/worker-management/actions/runs/40174879698

Dependency position: Backend/frontend production-only audits passed with zero findings; initial full frontend installation reported one high-severity finding in the wider dependency set.

A01 Broken Access Control

Broken Access Control PARTIALLY EVIDENCED Worker role JWT guards and assignment ownership conflicts are covered by unit tests. Current CI does not prove every route/cross-service access path. backend/src/auth/guards/worker-role.guard.ts; backend/src/database/repositories/task.repository.spec.ts

Required follow-up Run authenticated E2E matrix: own/other worker, inactive worker, manager/nonworker, WebSocket.

A02 Cryptographic Failures

Cryptographic Failures PARTIALLY EVIDENCED bcrypt password compare and signed JWT worker login exist; local HTTP or cloud TLS certificate not proven. Socket exp check implemented. backend/src/auth/auth.service.spec.ts; backend/src/realtime/wkms-realtime.gateway.spec.ts

Required follow-up Verify bcrypt factor, HTTPS/WSS and secret rotation in staging.

A03 Injection

Injection PARTIALLY EVIDENCED Parameterized pg SQL and validated message envelopes exist; exhaustive injection and hostile message fuzzing not demonstrated. backend/src/database/repositories/task.repository.ts; backend/src/messaging/contracts/checkout-completed.validator.spec.ts

Required follow-up Add malicious SQL-like payloads, malformed AMQP input and API DTO fuzzing.

A04 Insecure Design

Insecure Design PARTIALLY EVIDENCED Row locks/max-three-task rule, message deduplication and outbox design tested in units; formal security threat model not signed off. backend/src/database/repositories/task.repository.spec.ts; backend/src/messaging/outbox/outbox-dispatcher.service.spec.ts

Required follow-up Complete threat model and isolation/failure tests against disposable services.

A05 Security Misconfiguration

Security Misconfiguration PARTIALLY EVIDENCED Joi startup validation and socket origin restriction are implemented, but hard-coded localhost origin and cloud deployment requirements need acceptance. backend/src/config/env.validation.spec.ts; backend/src/realtime/wkms-realtime.gateway.ts

Required follow-up Configure allowlisted production origins and verify deployed secrets/headers.

A06 Vulnerable and Outdated Components

Vulnerable and Outdated Components OPEN DEVELOPMENT RISK Prod-only audits pass 0 on both backend/frontend. Initial frontend full installation reported one HIGH vulnerability; transitive dev-dependency details not documented. WKMS CI 40174879698; .github/workflows/ci.yml

Required follow-up Capture complete npm audit report, remediate or risk-accept with owner/date.

A07 Identification and Authentication Failures

Identification and Authentication Failures PARTIALLY EVIDENCED Inactive/non-WORKER denial and JWT validation tested; login brute force, refresh/session invalidation, centralized Auth compatibility require validation. backend/src/auth/auth.service.spec.ts; backend/src/realtime/wkms-realtime.gateway.spec.ts

Required follow-up Run login rate-limit/lockout and expiry/revocation tests in integration environment.

A08 Software and Data Integrity Failures

Software and Data Integrity Failures PARTIALLY EVIDENCED npm ci lockfiles, immutable workflow checks, event-version validation and outbox retries exist. Artifact signing and supply-chain provenance not verified. backend/src/messaging/contracts/order-ready.validator.spec.ts; .github/workflows/ci.yml

Required follow-up Assess workflow permissions, action pinning, trusted releases and dependencies.

A09 Security Logging and Monitoring Failures

Security Logging and Monitoring Failures PARTIALLY EVIDENCED Service logs and error paths exist; central audit of task state changes, escalation alerting and production monitor not verified. backend/src/tasks/task.service.ts; backend/src/tasks/task-escalation.service.spec.ts

Required follow-up Verify security event audit, secret redaction and centralized incident alerts.

A10 Server-Side Request Forgery

Server-Side Request Forgery NOT VERIFIED Broker/database URLs are server-configured; no dedicated outbound URL allowlist/SSRF test was identified. backend/src/config/env.validation.ts; backend/src/messaging/rabbitmq/rabbitmq.config.ts

Required follow-up Test arbitrary URL rejection and trusted upstream configuration.

8. Outstanding security acceptance

• Resolve or formally disposition the specific full-tree dependency findings at their tested release revisions; preserve npm audit JSON and CI rerun evidence.

• Complete an endpoint/role/tenant/object authorization matrix, including worker ownership, guest session scope, receptionist and manager operations, and negative tests.

• Verify login-abuse protections, token expiration/revocation, TLS/WSS, database and broker transport encryption, CORS/origin allowlists, security headers, SSRF, and outbound service trust.

• Run malformed-input and injection checks, log and alert tests, secret/PII redaction, signed deployment integrity checks, and recovery/security drills in an approved staging environment.

• Obtain a dated owner/reviewer decision with evidence and residual-risk disposition before describing the platform as security-compliant.